

Severity	Finding	Primary action
Low	Upload pre-filter trusts client MIME type	Routine cleanup.

Detailed Findings

High Risk

Default admin credentials remain in seed/docs

Severity: High

Evidence: backend/prisma/seed.ts:113-126; README.md:118-121

Risk: If the seeded admin account or password is still valid in production, an attacker can log in as an administrator.

Recommendation: Change the admin password immediately, remove default credentials from public docs, disable seed-admin creation in production, and require 2FA for admins.

Admin-controlled ad HTML is rendered publicly

Severity: High

Evidence: frontend/src/components/AdBanner.tsx:59;
backend/src/controllers/configController.ts:35-47

Risk: A compromised admin account or unsafe ad snippet can become stored XSS or a malicious third-party script vector across public pages.

Recommendation: Replace arbitrary HTML ads with structured ad settings, sanitize tightly, or render ads inside sandboxed iframes with a strict allowlist.

Article body iframes allow high-risk third-party embed hosts

Severity: High

Evidence: backend/src/utils/sanitize.ts:177-189; frontend/src/pages/public/ArticlePage.tsx:85-96

Risk: Code execution platforms and broad iframe allowlists increase phishing, tracking, and content-execution risk inside article pages.

Recommendation: Allow only YouTube by default. If code demos are required, sandbox every non-YouTube iframe with minimal permissions and remove broad host regexes.

Production protections depend heavily on NODE_ENV=production

Severity: High

Evidence: backend/src/app.ts:93-101; backend/src/middleware/rateLimiters.ts:15-25;
backend/src/config/env.ts:36-69